

Secure Software Development Lifecycle (SSDLC)

Owner: Transformative Leadership Lab LLC · **Applies to:** Meeting Cost Meter (Zoom App)

Contact: thomas+mcsupport@txl-lab.com · **Effective:** 1 June 2026 · **Review:** annually or on material change

Meeting Cost Meter is built and operated by a small team. This document describes the security controls that are **actually in place**. It intentionally makes no claim of SOC 2, ISO 27001, or third-party penetration testing, none of which we currently hold.

Purpose & scope

This SSDLC governs how changes to the Meeting Cost Meter application (this repository and its hosted service) are designed, built, reviewed, tested, and released, so that security is addressed at each stage rather than bolted on afterward.

Principles

- **Least data.** The app collects only what it needs (the presenter's own opportunity-cost estimates and Zoom-provided meeting context). No HR/payroll/SSO/directory integration.
- **Least privilege.** Secrets are injected as environment variables, never committed.
- **Defense in depth.** Session-only data (nothing persisted server-side), security headers, input validation, and automated checks in CI.
- **Reviewable change.** Every change is a small, documented pull request that a second reviewer and an automated check must approve before it reaches `main`.

Lifecycle

1. **Plan / specify.** Each change starts from a short written spec (`reviews/<slug>.md`) stating the problem, scope, and acceptance criteria — including any security impact.
2. **Develop.** Work happens on a short-lived feature branch. A pre-commit **secret-scanning git hook** (`.github/hooks/` , `scripts/secret-scan/`) blocks commits that contain likely credentials. Direct commits to `main` are blocked.
3. **Review.** Every change is opened as a pull request and receives an **independent code review** (an automated reviewer plus human approval) that explicitly considers correctness and security before merge.
4. **Test gate.** Automated tests must pass (`npm test`) and the client must build (`npm run build`) before merge — enforced both locally (the pre-merge gate) and in GitHub CI (`.github/workflows/ci.yml`).
5. **Static analysis (SAST).** **GitHub CodeQL** (`.github/workflows/codeql.yml`) scans the JavaScript/TypeScript on every push and pull request to `main` , plus a weekly scheduled

scan. Findings surface in the repository's Code scanning view.

6. **Dependency review. Dependabot** (`.github/dependabot.yml`) opens weekly PRs for vulnerable/outdated npm and GitHub-Actions dependencies; GitHub dependency alerts are enabled. See `dependency-management.md` .
7. **Merge control (authoritative)**. `main` is protected by a repository **ruleset**: a pull request is required, the **CodeQL** and **CI** status checks must pass, and force-pushes and branch deletion are blocked. This section is the single source of truth for the required checks; other documents reference it rather than restating the list.
8. **Release / deploy**. Merging to `main` triggers an automatic deploy to Railway, gated by a `/api/health` check. Configuration and secrets are environment variables, set per environment, never in the repository.
9. **Operate & monitor**. Runtime errors and client-reported diagnostics are logged to the hosting platform (minimized at the source, not intentionally populated with secrets or presenter figures; see `data-retention-and-protection.md` for what logs may contain). Issues feed back into step 1.

Data security in the lifecycle

- Presenter configuration is **session-only** — held in the browser and never persisted server-side, so there is no stored data to encrypt or expose. See `data-retention-and-protection.md` .
- All responses set HTTPS/HSTS, Content-Security-Policy, `X-Content-Type-Options: nosniff` , `Referrer-Policy` , and `no-store` cache headers.

What we do not currently do

- No commercial Dynamic Application Security Testing (DAST).
- No third-party penetration test.
- No SOC 2 or ISO 27001 certification.

These are candidate future investments; we do not represent them as in place today.